

Professional Pentest / Red Team Reporting

Evidence, Risk Communication, Attack-Path Narrative, Remediation, Retest, and Report QA

Learning objectives

- Menyusun report yang berguna bagi executive, engineering, security, dan remediation owners tanpa mencampur kebutuhan tiap audience.
- Menulis finding yang reproducible, evidence-driven, defensible, dan fokus pada root cause + impact, bukan sekadar tool output.
- Membedakan technical severity, exploitability, business impact, dan organizational risk; menggunakan CVSS v4.0 dengan benar bila diwajibkan.
- Menyusun attack-path narrative yang menjelaskan bagaimana beberapa weakness membentuk impact yang lebih besar daripada finding individual.
- Melakukan report QA: scope consistency, evidence integrity, secret leakage, screenshot hygiene, remediation quality, retest state, dan final delivery security.

Prerequisites & tooling

- Module 00-24, terutama scope/RoE, evidence handling, vulnerability assessment, exploitation, AD, pivoting, ATT&CK, dan detection-aware operations.
- Markdown editor / Obsidian / VS Code, Python 3, sha256sum, optional LibreOffice/Word untuk final formatting.

omarchy pkg add python jq ripgrep libreoffice-fresh

Core principle - Assessment yang hebat tetapi tidak dapat dipahami, direproduksi, diprioritaskan, atau diperbaiki adalah deliverable yang gagal. Reporting bukan pekerjaan administrasi setelah testing; reporting adalah bagian dari testing sejak evidence pertama dibuat.

1. Report adalah Produk Utama Engagement

OWASP WSTG menekankan bahwa technical testing hanya setengah dari assessment; hasil akhirnya adalah report yang jelas untuk management dan technical staff. NIST SP 800-115 juga memperlakukan planning, execution, analysis, dan reporting sebagai satu lifecycle. Dalam praktik consultancy, report menjadi record formal tentang scope, observations, attack paths, business impact, remediation, limitations, dan apa yang benar-benar dibuktikan selama engagement.

1.1 Empat audience utama

Audience	Butuh jawaban apa?	Jangan lakukan
Executive / owner	Apa risiko utama? Apa impact ke bisnis? Apa prioritas 30/60/90 hari?	Dump command, jargon, dan screenshot tanpa konteks.
Engineering	Root cause-nya apa? Komponen mana? Bagaimana reproduce dan memperbaiki?	Remediation generik seperti "sanitize input" tanpa desain fix.
Security / SOC	Attack path, telemetry, identity, IOC/TTP, control gap, retest evidence.	Mengklaim detection gagal tanpa telemetry prerequisite.
Audit / governance	Scope, authorization, methodology, evidence traceability, limitations, status.	Menyembunyikan gap coverage atau asumsi penting.

1.2 Report architecture yang production-ready

Cover / Classification
 -> Executive Summary
 -> Scope & Rules / Constraints
 -> Methodology
 -> Attack Path / Engagement Narrative
 -> Findings Summary
 -> Detailed Findings
 -> Remediation Roadmap
 -> Retest Status
 -> Limitations
 -> Appendix / Evidence / References

Tidak semua engagement membutuhkan urutan identik. External pentest, web/API assessment, red-team exercise, cloud review, dan retest punya emphasis berbeda. Struktur harus membantu pembaca mengambil keputusan, bukan mengikuti template secara membabi buta.

2. Evidence Standard: Observation -> Proof -> Claim

Finding yang defensible punya chain of evidence yang jelas. Evidence bukan berarti screenshot sebanyak mungkin. Evidence berarti data minimum yang cukup untuk mendukung claim, dapat ditelusuri ke waktu/asset/test step, dan disimpan dengan hygiene yang aman.

2.1 Evidence quality model

Dimensi	Pertanyaan QA
Attribution	Asset, account, endpoint, request, atau host mana yang dibuktikan?
Time	Apakah timestamp UTC / timezone diketahui?
Reproducibility	Bisakah tester kompeten mengulang langkah dengan scope/credential yang sama?
Integrity	Apakah raw evidence diberi hash / index sehingga perubahan dapat dideteksi?
Minimality	Apakah bukti cukup tanpa mengekspos data lebih banyak dari yang diperlukan?
Context	Apakah baseline dan modified observation terlihat?
Chain	Apakah evidence jelas mendukung claim dan bukan sekadar output tool?

2.2 Raw evidence vs report evidence

Raw evidence	Report evidence
Full request/response, console log, pcap, JSON, screenshot asli.	Cuplikan relevan yang menjelaskan finding.
Disimpan restricted; bisa mengandung data sensitif.	Redacted/minimized untuk audience report.
Digunakan untuk reproduksi, dispute, retest.	Digunakan untuk komunikasi dan decision-making.

Security note - Report pentest sendiri adalah sensitive asset: dapat berisi attack path, hostname, version, credential artifact, internal architecture, screenshot data, dan remediation gap. Terapkan least privilege, encryption at rest/in transit, retention policy, dan secure deletion sesuai engagement.

2.3 Evidence naming

RT-003_2026-10-05T02-15-30Z_api-bola_baseline.txt
 RT-003_2026-10-05T02-16-04Z_api-bola_cross-user.txt
 RT-003_2026-10-05T02-18-11Z_response-diff.png

Nama evidence sebaiknya mengandung finding/reference, timestamp, asset/behavior, dan tipe bukti. Hindari nama seperti screenshot1.png atau final-final2.txt.

3. Anatomy of a High-Quality Finding

OWASP WSTG merekomendasikan finding yang memberi technical team informasi cukup untuk memahami vulnerability, replicate, dan resolve. OffSec juga menekankan dokumentasi step-by-step yang dapat direplikasi oleh pembaca teknis. Untuk dunia kerja, finding harus self-contained namun tidak mengulang seluruh methodology engagement.

Bagian	Isi yang diharapkan
Reference / title	ID stabil + title spesifik pada weakness/impact, bukan nama tool.
Severity / risk	Rating + rationale; CVSS vector bila engagement memerlukan.
Affected assets	Host/app/endpoint/component/version yang benar-benar tervalidasi.
Summary	Apa yang salah, siapa yang dapat memanfaatkannya, dan apa impact utamanya.
Preconditions	Access, role, network position, configuration, user interaction.
Technical details	Root cause, trust boundary, behavior, why control failed.
Evidence	Baseline + changed condition + observed result; path ke raw evidence.
Reproduction	Minimal deterministic steps, bukan diary seluruh session.
Impact	Technical + business consequence yang realistis dan scoped.
Remediation	Root-cause fix, compensating controls, testing guidance.
Retest	Fixed / partial / unresolved / not retested + new evidence.

3.1 Bad finding vs good finding

Lemah	Lebih kuat
"Nmap menemukan port 445 open - High."	"SMB signing tidak diwajibkan pada server X; authenticated relay path tervalidasi di lab-equivalent scope - severity berdasarkan prerequisites + impact."
"SQL injection critical."	"Unauthenticated input pada parameter category mengubah SQL predicate dan membaca records lintas category; no destructive action performed."
"Update software."	"Upgrade ke fixed version X atau vendor-supported equivalent; validasi bahwa vulnerable code path tidak reachable; tambahkan regression test."

3.2 Reproduction: cukup detail, tidak berisik

Reproduction harus menjawab prerequisites, exact target, request/command yang penting, expected baseline, modified input, observed result, dan cleanup bila state berubah. Jangan menyalin 200 baris terminal jika tiga baris cukup. Simpan full transcript sebagai evidence bila diperlukan.

4. Severity, CVSS, dan Business Risk

FIRST menegaskan bahwa CVSS Base mengukur severity intrinsik, bukan organizational risk. CVSS v4.0 memiliki Base, Threat, Environmental, dan Supplemental metric groups. Jika mempublikasikan CVSS, sertakan score dan vector agar pembaca dapat memahami derivasi. Jangan menaikkan rating karena "terlihat hacker-ish"; rating harus dapat dipertahankan dengan prerequisites, exploitability, blast radius, asset criticality, data class, compensating controls, threat context, dan business impact.

4.1 Severity != risk

Technical Severity + Threat Context + Environment + Business Impact + Compensating Controls -> Risk Decision

Signal	Pertanyaan
Exploitability	Remote/local? Auth? Privilege? User interaction? Complexity?
Reachability	Apakah vulnerable code/path benar-benar reachable pada deployed architecture?
Impact	Confidentiality, integrity, availability, subsequent-system impact.
Asset criticality	Production? Payment? Identity? Domain control? Safety-related?
Threat	Known exploitation? Public PoC? Active campaign? Internal-only?
Control strength	MFA, segmentation, allow-list, WAF, EDR, monitoring, backups.

4.2 Qualitative matrix

Repo menyediakan severity-matrix.py hanya untuk latihan likelihood x impact. Tool ini bukan CVSS dan tidak boleh disajikan sebagai standar industri. Engagement harus menyepakati rating methodology pada pre-engagement agar severity tidak berubah-ubah berdasarkan selera tester.

```
python severity-matrix.py --likelihood 4 --impact 5
```

4.3 CVSS hygiene

- Gunakan kalkulator/specification resmi FIRST dan simpan vector, bukan score saja.
- Jelaskan asumsi yang menentukan Attack Requirements, Privileges Required, User Interaction, dan impacts.
- Gunakan Threat/Environmental metrics jika proses organisasi memang mendukungnya; jangan menyebut Base score sebagai "business risk".
- Kalau CVSS tidak cocok untuk business-logic finding, gunakan agreed qualitative model + rationale yang transparan.

5. Attack-Path Narrative: Dari Findings ke Impact

Red-team report tidak boleh terasa seperti vulnerability scanner export. Nilai utamanya sering berada pada chain: initial foothold -> credential/control weakness -> privilege transition -> internal access -> objective. Attack-path narrative menjelaskan dependencies antar-finding dan menunjukkan mengapa beberapa weakness medium dapat membentuk enterprise impact yang tinggi.

5.1 Attack path card

Field	Contoh
Starting condition	External low-privilege application account.
Step 1	BOLA exposes internal identifier / sensitive record.

Step 2	Credential/config exposure yields scoped service identity.
Step 3	Service identity has excessive directory permission.
Step 4	Authorized lab validation demonstrates privilege path.
Objective	Access to sensitive dummy asset / domain-equivalent control in lab.
Detection notes	Which steps were detected/logged-only/not-testable.
Break points	Controls that would interrupt the chain.

5.2 Causality rules

- Bedakan demonstrated path dari hypothetical path. Label “validated”, “plausible”, atau “not tested”.
- Jangan menggabungkan findings yang tidak punya dependency nyata hanya agar attack path terlihat dramatis.
- Tuliskan break points: MFA, segmentation, least privilege, object authorization, certificate policy, monitoring, atau process control yang memutus chain.
- Gunakan timeline atau graph hanya jika memperjelas message; visual bukan dekorasi.

6. Executive Summary yang Berguna

Executive summary harus menjelaskan outcome engagement dalam bahasa business-readable. OWASP menyarankan summary yang konstruktif, meaningful, tidak penuh jargon, dan menggunakan grafik hanya bila membantu message. Executive tidak membutuhkan command detail; mereka perlu scope, overall posture, material attack paths, business consequences, strengths/limitations, dan prioritized actions.

6.1 Struktur ringkas

Bagian	Contoh isi
Why / scope	Apa yang diuji, kapan, dan objective utama.
Outcome	Apa yang berhasil dibuktikan dan apa yang tidak.
Top risk	1-3 attack paths/finding paling material.
Positive controls	Control yang efektif dan membatasi impact.
Priorities	Immediate / 30-day / 90-day actions.
Limitations	Area penting yang tidak bisa diuji / telemetry gap.

6.2 Language rules

Hindari	Gunakan
“The security is terrible.”	“The tested path permits X under Y prerequisites; impact is Z.”
“Hackers can easily own everything.”	“A low-privilege identity can reach domain-equivalent privilege through the validated chain.”
“Critical because CVSS 9.8.”	“Critical because validated impact reaches asset X with prerequisites Y; CVSS-B is supporting severity context.”
“No issues found.”	“No material issues were identified within the tested scope and constraints; limitations remain ...”

7. Remediation: Fix Root Cause, bukan Gejala

Remediation yang bagus dapat ditindaklanjuti, proporsional, dan dapat diverifikasi. Hindari “sanitize input”, “use strong passwords”, “enable security”, atau “update” tanpa konteks. Berikan primary fix, compensating controls, dependency/owner jika diketahui, dan retest criteria.

7.1 Remediation layers

Layer	Contoh
Immediate containment	Disable vulnerable endpoint, revoke exposed credential, restrict route, temporary deny rule.
Root-cause fix	Server-side authorization, prepared statement, ACL redesign, template policy correction.
Structural improvement	Central authz middleware, secrets manager, secure SDLC test, tiering model.
Detection / response	Add behavior analytic, alert enrichment, retention, playbook.
Validation	Regression test + retest evidence demonstrating previous path now fails.

7.2 Prioritization roadmap

0-7 days: containment / credential revocation / exposed control

30 days: root-cause fixes for material attack paths

60-90 days: architectural / process / detection improvements

Retest: validate fixes + regression + attack-path break

Timeline di atas hanya contoh. Jangan memberi SLA tanpa memahami organization, regulatory obligations, exploit activity, maintenance windows, dan business constraints.

8. Screenshot & Data Hygiene

Screenshot harus membuktikan satu message. Crop secukupnya tetapi jangan hilangkan context penting. Hindari menampilkan customer data, tokens, cookies, secrets, personal data, unrelated terminal history, browser bookmarks, desktop notifications, hostname/usernames yang out-of-scope, atau local paths yang mengungkap data operator.

8.1 Screenshot checklist

Check	Pertanyaan
Purpose	Apa claim yang dibuktikan screenshot ini?
Context	Target/endpoint/user/time cukup terlihat?
Secret hygiene	Token/password/cookie/API key sudah di-redact?
Data minimization	Apakah PII/business data yang tidak perlu sudah dihilangkan?
Legibility	Font terbaca di PDF 100%?
Integrity	Raw evidence asli tetap disimpan terpisah bila diperlukan?
Annotation	Highlight/callout membantu tanpa menutupi evidence?

Redaction warning - Menutupi teks dengan kotak hitam di editor gambar/PDF tidak selalu menghapus underlying data. Untuk final sensitive report, gunakan true redaction workflow dan verifikasi hasil render/extraction. Jangan menganggap blur sebagai penghapusan data.

9. Retest & Finding Lifecycle

Retest bukan sekadar menjalankan exploit lama lagi. Tanyakan apakah root cause diperbaiki, apakah alternate path masih ada, apakah compensating control bekerja, dan apakah regression diperkenalkan. Status harus jelas dan evidence baru dipisahkan dari evidence assessment awal.

Status	Definisi
Fixed	Previous attack condition no longer succeeds; root-cause/control evidence supports closure.
Partially fixed	Some vector/asset fixed tetapi residual path atau incomplete control masih ada.
Not fixed	Original behavior masih reproducible.
Risk accepted	Owner menerima risk secara formal; bukan berarti technical issue hilang.
Not retested	Tidak ada cukup waktu/access/scope untuk memvalidasi fix.

9.1 Reproducibility standard

OffSec reporting guidance menuntut dokumentasi cukup detail agar serangan dapat direplikasi step-by-step oleh pembaca teknis. Dalam consultancy, prinsip yang sama berlaku tetapi dengan data minimization: simpan full transcript di evidence store, tampilkan minimal reproduction yang deterministic di report.

10. Report QA sebelum Delivery

Final report perlu technical review dan editorial/security review. Satu typo asset ID atau screenshot token dapat lebih merusak kepercayaan daripada styling yang kurang cantik.

10.1 QA gates

Gate	Check
Scope	Semua asset/finding benar-benar in-scope atau jelas dilabel observation/out-of-scope.
Evidence	Setiap claim material punya evidence; hash/index tersedia untuk raw evidence.
Severity	Rationale konsisten; CVSS vector ada jika score dipakai.
Reproduction	Prerequisites dan deterministic steps cukup; destructive step tidak dibutuhkan.
Remediation	Fix root cause, bukan cuma symptom; retest criteria jelas.
Secrets/PII	No live credentials, token, private key, cookie, unrelated PII.
Consistency	Ref ID, hostname, endpoint, title, severity konsisten di summary/detail.
Language	Constructive, factual, no unsupported attribution/speculation.
Delivery	Correct recipient, encryption/channel, classification, retention.

10.2 Automated Markdown QA

```
python report-qa.py report.md --evidence-root ../02-evidence
```

Helper module memeriksa section penting, placeholder TODO/TBD/FIXME/CHANGEME, beberapa pola secret obvious, dan reference [evidence:path]. Ini hanya linting; tidak menggantikan reviewer manusia atau DLP/security scanning organisasi.

11. Technical Writing Patterns

Technical correctness saja tidak cukup; report harus menghindari ambiguity. Gunakan subject yang jelas, active voice bila cocok, exact asset identifiers, dan terminology yang konsisten. Pisahkan observation dari inference: “server returned X” adalah observation; “hal ini menunjukkan Y” adalah interpretation. Jika confidence rendah, tulis confidence dan missing evidence.

11.1 Claim ladder

Level	Contoh
Observation	GET /orders/102 sebagai user Alice mengembalikan record milik Bob.
Validated weakness	Server tidak melakukan object-level authorization untuk requested order.
Demonstrated impact	Alice dapat membaca satu cross-user training record.
Potential impact	Jika pattern berlaku ke seluruh object set, confidentiality exposure dapat meluas.
Business consequence	Paparan data pelanggan dapat memicu privacy/compliance impact - perlu konfirmasi data classification.

Jangan melompat dari observation ke worst-case business claim tanpa evidence. Report yang kredibel membedakan apa yang dibuktikan, apa yang disimpulkan, dan apa yang masih memerlukan validasi.

11.2 Finding title patterns

Kurang jelas	Lebih informatif
Weak Authentication	Password reset token remains valid after account password change
Misconfiguration	Internet-exposed administration interface allows password-only authentication
Information Disclosure	Verbose API response exposes internal account classification to ordinary users
Privilege Escalation	Service configuration writable by standard users is consumed by privileged service

11.3 Duplicate vs root-cause grouping

Satu root cause dapat muncul pada banyak endpoints/assets. Jangan otomatis membuat puluhan findings identik. Pilih grouping yang membantu remediation: satu finding dengan affected-assets table jika fix/control sama; pisahkan bila owner, root cause, exploitability, impact, atau remediation berbeda. Scanner count bukan finding count.

12. CVSS v4.0 Worked Reasoning

Jika engagement mewajibkan CVSS, dokumentasikan reasoning per metric sebelum melihat score. Ini mengurangi bias “ingin severity tertentu”. CVSS v4.0 memisahkan impact pada Vulnerable System dan Subsequent System serta menambahkan Attack Requirements. Gunakan official calculator/specification dan jangan menghafal vector dari contoh internet.

12.1 Example reasoning worksheet

Metric family	Pertanyaan reviewer
Attack Vector	Dari mana attacker harus berinteraksi dengan vulnerable component?
Attack Complexity	Adakah kondisi di luar control attacker yang membuat exploit tidak selalu repeatable?

Attack Requirements	Adakah deployment condition/prerequisite yang harus ada sebelum attack bisa dilakukan?
Privileges Required	Privilege apa yang harus dimiliki sebelum exploitation?
User Interaction	Apakah user lain harus melakukan action?
VC/VI/VA	Apa impact pada confidentiality/integrity/availability vulnerable system?
SC/SI/SA	Apakah impact menyebar ke subsequent system/security authority?

Setelah Base vector, baru pertimbangkan Threat dan Environmental metrics jika engagement memiliki data yang cukup. Simpan vector di finding supaya score dapat dihitung ulang saat environment berubah.

13. Red Team Campaign Reporting

Red-team reporting berbeda dari vulnerability list karena objective sering berupa control validation. Report harus menunjukkan campaign phases, operator actions yang relevan, detections, blocked paths, assumptions, safety stops, dan objective attainment. Jangan menilai success hanya dari “domain admin” atau shell. Control yang memblokir attack path juga merupakan hasil penting.

13.1 Campaign outcome matrix

Step	Outcome	Defender view	Report treatment
Initial access simulation	Blocked	Preventive control fired	Document successful control + evidence.
Discovery	Logged-only	Telemetry present, no analytic	Detection opportunity / control gap.
Credential path	Not tested	Outside RoE	Explicit limitation; no assumption.
Lateral move	Detected	Alert + analyst action	Validate timeline and analyst context.
Objective	Not reached	Prior controls broke chain	Explain break point and residual risk.

13.2 Detection outcome narrative

Gunakan vocabulary konsisten dari Module 24: blocked, detected, logged-only, missed, not-testable. Untuk setiap detection claim, sebutkan expected telemetry, actual telemetry, analytic/alert, analyst response bila in-scope, dan timestamp. “EDR did not alert” tanpa membuktikan sensor/telemetry aktif bukan finding yang kuat.

14. Report Security, Classification, and Delivery

Report sering lebih sensitif daripada sebagian raw scan karena menggabungkan weakness, attack paths, architecture, identities, dan remediation gaps dalam satu file. Delivery workflow harus ditentukan sebelum final report selesai.

14.1 Handling checklist

Control	Minimum practice
Classification	Mark internal/confidential/restricted sesuai policy engagement.
Access	Need-to-know recipients; hindari broad shared-link default.
Transport	Approved encrypted channel; verify recipient identity/domain.
At-rest	Encrypted managed storage; no personal cloud/USB tanpa approval.
Versioning	Unique version + date + hash; hindari final-v7-reallyfinal.pdf.
Retention	Delete/archive date sesuai contract/policy; include raw evidence separately.
Correction	Defined contact/process bila factual error ditemukan setelah delivery.

14.2 Metadata hygiene

Final DOCX/PDF dapat membawa author metadata, comments, tracked changes, hidden text, attachments, cached fields, atau old revision content. Sebelum delivery, accept/reject tracked changes sesuai process, strip reviewer comments jika final, scrub metadata, render PDF, lalu lakukan text extraction/search untuk memastikan secret/redacted value tidak tersisa.

14.3 True redaction

Redaction harus menghapus underlying content, bukan hanya menutup visual. Untuk PDF, gunakan true redaction tool lalu re-render dan text-extract untuk verifikasi. Untuk screenshot, buat sanitized derivative dan pertahankan raw original restricted. Jangan melakukan edit langsung terhadap satu-satunya evidence asli.

15. Peer Review & Editorial Discipline

Report yang matang biasanya melewati minimal dua review lens. Technical review mencari factual error dan reproducibility gap; editorial/security review mencari ambiguity, inconsistent severity, secret leakage, unsupported business claims, layout defect, dan delivery risk.

15.1 Reviewer checklist

Reviewer	Pertanyaan utama
Technical	Apakah root cause benar? Reproduction valid? Evidence cukup? Remediation memperbaiki cause?
Risk owner / lead	Severity konsisten? Attack path material? Business claim punya evidence/context?
Editorial	Bahasa jelas? Terminology konsisten? Duplicate? Table/figure readable?
Security/privacy	Ada secret/PII? Redaction benar? Metadata/comment aman? Recipient sesuai?

15.2 Common report defects

- Asset di findings summary berbeda dengan detailed finding.
- Severity berubah antara executive summary dan technical section.
- Screenshot menampilkan token/credential yang tidak diperlukan.
- Remediation tidak dapat diuji atau hanya menyarankan “use security best practices”.
- Finding menyebut exploit berhasil tetapi tidak menunjukkan baseline/modified delta.
- Attack path memasukkan step hypothetical tanpa label.
- Retest menimpa bukti original sehingga historical state hilang.
- Report menyatakan “no vulnerabilities” padahal scope/time/credential limitation signifikan.

16. Hands-on Labs

Semua lab hanya memproses file lokal. Tidak ada scanning, exploitation, credential attack, atau network target. Gunakan evidence dari module-module sebelumnya atau sample local evidence.

Lab 01 - Reporting workspace

```
./workspace-init.sh module25-reporting
```

Review struktur 00-admin, notes, evidence, findings, report, retest, dan QA. Pastikan permission private sesuai kebutuhan.

Lab 02 - Buat finding template

```
python finding-note.py module25-reporting/03-findings/RT-001.md --ref RT-001 --title 'Broken object-level authorization' --severity High --asset 'training API'
```

Isi Preconditions, Technical details, Evidence, Reproduction, Impact, Remediation, dan Retest. Fokus pada root cause, bukan tool yang menemukan issue.

Lab 03 - Evidence index & hash

```
python evidence-index.py module25-reporting/02-evidence --output module25-reporting/06-qa/evidence.csv
./evidence-manifest.sh module25-reporting/02-evidence module25-reporting/06-qa/evidence-manifest.sha256
```

Ubah satu file evidence training dan jalankan sha256sum -c terhadap manifest untuk melihat integrity failure.

Lab 04 - Severity calibration

```
python severity-matrix.py --likelihood 4 --impact 5
```

Tuliskan alasan likelihood dan impact. Kemudian bandingkan dengan CVSS v4.0 resmi untuk satu vulnerability teknis. Catat mengapa hasil qualitative risk dan CVSS-B tidak harus sama.

Lab 05 - Baseline vs modified evidence

Ambil finding dari Module 11/13 local lab. Simpan baseline request/response dan modified request/response. Di finding, jelaskan satu controlled variable dan response delta; jangan hanya tempel screenshot.

Lab 06 - Attack-path narrative

Pilih 3 finding training yang dapat di-chain. Buat satu attack-path card: starting condition, setiap transition, privilege/access gained, validated vs hypothetical steps, objective, break points, dan detection outcome.

Lab 07 - Executive summary rewrite

Ambil technical attack-path paragraph dan tulis ulang maksimum 180 kata untuk executive. Hilangkan command/tool names kecuali benar-benar material. Tambahkan top 3 remediation priorities.

Lab 08 - Remediation quality review

Untuk tiga findings, buat: immediate containment, root-cause fix, structural improvement, detection/monitoring improvement, dan retest criteria. Tandai recommendation yang membutuhkan owner lain atau architecture change.

Lab 09 - Screenshot/data hygiene

Ambil screenshot training. Pastikan hanya claim-relevant area yang terlihat; redact dummy token/PII secara benar pada copy untuk report, dan simpan raw evidence terpisah restricted. Verifikasi bahwa underlying data tidak dapat diekstrak dari final artifact bila redaction dilakukan.

Lab 10 - Report linting

```
cp report-template.md module25-reporting/04-report/report.md
python report-qa.py module25-reporting/04-report/report.md --evidence-root module25-reporting/02-evidence
```

Isi template sampai QA PASS. Lalu masukkan placeholder TODO atau dummy secret pattern untuk melihat lint failure.

Lab 11 - Findings summary consistency

Buat tabel summary dengan Ref, Title, Severity, Asset, Status. Cross-check setiap row dengan detailed finding dan cari mismatch pada severity/asset/reference.

Lab 12 - Retest note

Duplikasi satu finding training ke folder 05-retest. Catat status Fixed/Partial/Not Fixed, tanggal UTC, build/version baru, reproduction lama, result baru, dan evidence path. Jangan overwrite evidence assessment awal.

Lab 13 - Full report assembly

Gabungkan executive summary, scope, methodology, attack path, finding summary, detailed findings, remediation roadmap, limitations, retest, dan appendix ke satu Markdown/DOCX draft. Review urutan agar pembaca non-teknis bisa berhenti setelah summary tanpa kehilangan message utama.

Lab 14 - Peer-review simulation

Lakukan dua pass: Technical reviewer memeriksa correctness/reproducibility; Editorial/security reviewer memeriksa clarity, data leakage, inconsistent identifiers, unsupported claim, dan final-delivery hygiene.

Lab 15 - Secure delivery checklist

Buat delivery record: report filename/version, SHA-256, classification, intended recipients, encrypted transport/storage method, retention/delete date, dan contact untuk correction. Jangan menyimpan live password di delivery record.

17. Capstone - Professional Assessment Report

Gunakan temuan dummy/local-lab dari Module 11-24. Buat report lengkap seolah engagement consultancy nyata. Minimal harus punya 4 findings dan 1 multi-step attack path. Semua claims harus didukung evidence dan semua scope/limitations harus eksplisit.

Deliverable	Minimum acceptance criteria
Executive summary	<= 1 page; business outcome + top risks + priorities + limitations.
Scope/methodology	Assets, window, assumptions, constraints, standards/workflow.
Attack path	Validated/hypothetical labels, break points, detection notes.
4 findings	Root cause, evidence, reproduction, impact, remediation, retest criteria.
Severity	Consistent methodology; CVSS vector if used.

Evidence	Indexed + SHA-256 manifest; report uses minimized/redacted evidence.
Remediation roadmap	Immediate / near-term / structural priorities.
QA	report-qa.py PASS + manual technical/editorial review.
Delivery record	Version/hash/classification/recipient/retention.

Capstone success - Lo lulus Module 25 ketika orang lain bisa membaca report tanpa chat dengan lo, memahami scope dan risk, mereproduksi findings penting, mengerti attack path, tahu apa yang harus diperbaiki dulu, dan dapat memverifikasi closure saat retest.

18. Cheat Sheet

Need	Minimum
Finding	Ref + title + severity/rationale + asset + summary + root cause + evidence + repro + impact + remediation + retest.
Evidence	Timestamp + asset/context + raw store + minimized report copy + integrity hash.
CVSS	Use official v4.0; publish score + vector; Base severity != risk.
Attack path	Start -> transitions -> gained access -> objective -> break points -> detection.
Executive	Outcome + material risk + positive controls + priorities + limitations.
QA	Scope, evidence, severity, secrets/PII, consistency, remediation, reproducibility, delivery.

18.1 Final acceptance rubric

Area	Pass condition
Accuracy	No unsupported claims; affected assets and prerequisites match evidence.
Reproducibility	A technically competent reader can repeat material findings from the documented prerequisites/steps.
Risk	Severity methodology is consistent; business claims are contextualized; CVSS vectors are reproducible if used.
Remediation	Recommendations address root cause and include practical validation criteria.
Attack path	Validated vs hypothetical transitions are clearly labeled; break points are identified.
Evidence	Raw evidence is indexed/hashed; report evidence is minimized and traceable.
Privacy/security	No live secrets, unnecessary PII, hidden comments/revisions, or ineffective visual-only redaction.
Readability	Executive can understand priorities; engineer can implement fixes; SOC can understand defensive implications.
Delivery	Correct version, recipients, classification, channel, retention, and SHA-256 recorded.

18.2 Delivery record example

```
report: ACME-Red-Team-Report-v1.0.pdf
classification: Confidential - Security
sha256: <64-hex-digest>
recipients: security-owner@example.test; engineering-owner@example.test
delivered_utc: 2026-10-05T03:00:00Z
channel: approved encrypted document exchange
raw_evidence: separately restricted
retention_review: 2027-01-05
correction_contact: security-assessment@example.test
```

Gunakan dummy values di lab. Di engagement nyata, delivery record mengikuti policy/contract. Jangan menaruh decryption password di channel atau record yang sama dengan encrypted report.

19. References

- NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment - <https://csrc.nist.gov/pubs/sp/800/115/final>
- OWASP Web Security Testing Guide - Reporting - https://wstg.owasp.org/latest/5-Reporting/01-Reporting_Structure/
- FIRST CVSS v4.0 User Guide - <https://www.first.org/cvss/v4.0/user-guide>
- FIRST CVSS v4.0 Specification - <https://www.first.org/cvss/v4.0/specification-document>
- OffSec OSCP+ Reporting Requirements - <https://help.offsec.com/hc/en-us/articles/360046787731-OSCP-Reporting-Requirements>
- OffSec OSCP+ Exam Guide / Documentation Requirements - <https://help.offsec.com/hc/en-us/articles/360040165632-OSCP-Exam-Guide>
- OWASP Risk Rating Methodology - https://owasp.org/www-community/OWASP_Risk_Rating_Methodology

Module 25 intentionally uses only local reporting utilities. No lab in this module performs scanning, exploitation, credential attacks, or remote actions.